Informe de resultados QA — Grupo 2

API y Seguridad | Informe ejecutivo de hallazgos | Allison Espaderos

Alcance: rama local grupo-2, FastAPI en 127.0.0.1:8000, Swagger y pruebas unitarias; conexión de login a base compartida. Este informe resume las evidencias reportadas durante la revisión, no constituye una auditoría de producción.

1. Resumen ejecutivo

Se revisaron los 38 escenarios del plan de QA. Este informe presenta los hallazgos relevantes y las limitaciones de verificación; el detalle de estados, notas y evidencias se mantiene en el registro de Google Sheets.

El login real devuelve JWT y funciona con cuentas QA, pero el middleware de Users/Roles usa una lista JSON temporal y una cabecera controlada por el cliente. Esta separación explica los HTTP 422 al usar Bearer y bloquea la comprobación de expiración, alteración y autorización por roles de extremo a extremo.

2. Hallazgos prioritarios

CRÍTICO — G2-10: suplantación por cabecera

La API permitió GET /users sin Authorization: Bearer; basta la cabecera usuario-actual de un administrador presente en el fixture. Corregir antes de despliegue y repetir G2-06, 08, 09, 10, 17, 37 y 38.

ALTO — G2-06: contrato de autenticación incumplido

GET /users sin credenciales devuelve 422 por cabecera faltante, no 401. Con Bearer válido también devuelve 422; el JWT no participa en la autorización.

ALTO — G2-05: logout ausente

No se identificó POST /auth/logout ni una revocación comprobable del token anterior.

ALTO — G2-34: bloqueo no conectado

Se identificaron contador y funciones de umbral, pero el login no parece invocarlas. No se ejecutaron cinco fallos sobre la base compartida.

MEDIO — G2-33: documentación incompleta

Swagger muestra las respuestas 401 y 409 como no documentadas.

PENDIENTE — archivos

No se encontró router de archivos; G2-18 a G2-22 no pudieron probarse.

3. G2-07 — Consulta del usuario autenticado

Estado: BLOQUEADO. No se identificó una implementación funcional de GET /me en Swagger ni en la búsqueda de rutas del código. Las referencias a /me aparecen en documentación y comentarios. Las solicitudes GET /api/v1/auth/me y GET /api/v1/me devolvieron HTTP 404 (NOT_FOUND). No fue posible comprobar la recuperación de la identidad y roles del usuario autenticado.

Pendiente: exponer el endpoint y verificar con JWT válido que devuelve solo los datos del usuario; comprobar además el rechazo de solicitudes sin token o con token inválido.